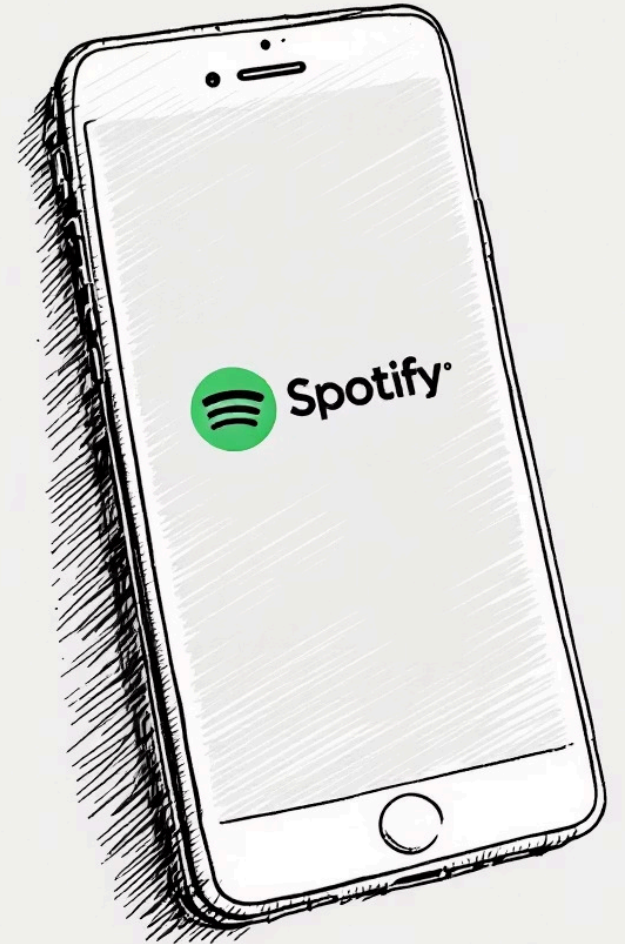


Login with Google in Spotify

OAuth 2.0 Authorization Code Flow (User Perspective)

- How Google Login works behind the scenes
- Focus on security, tokens, and ownership



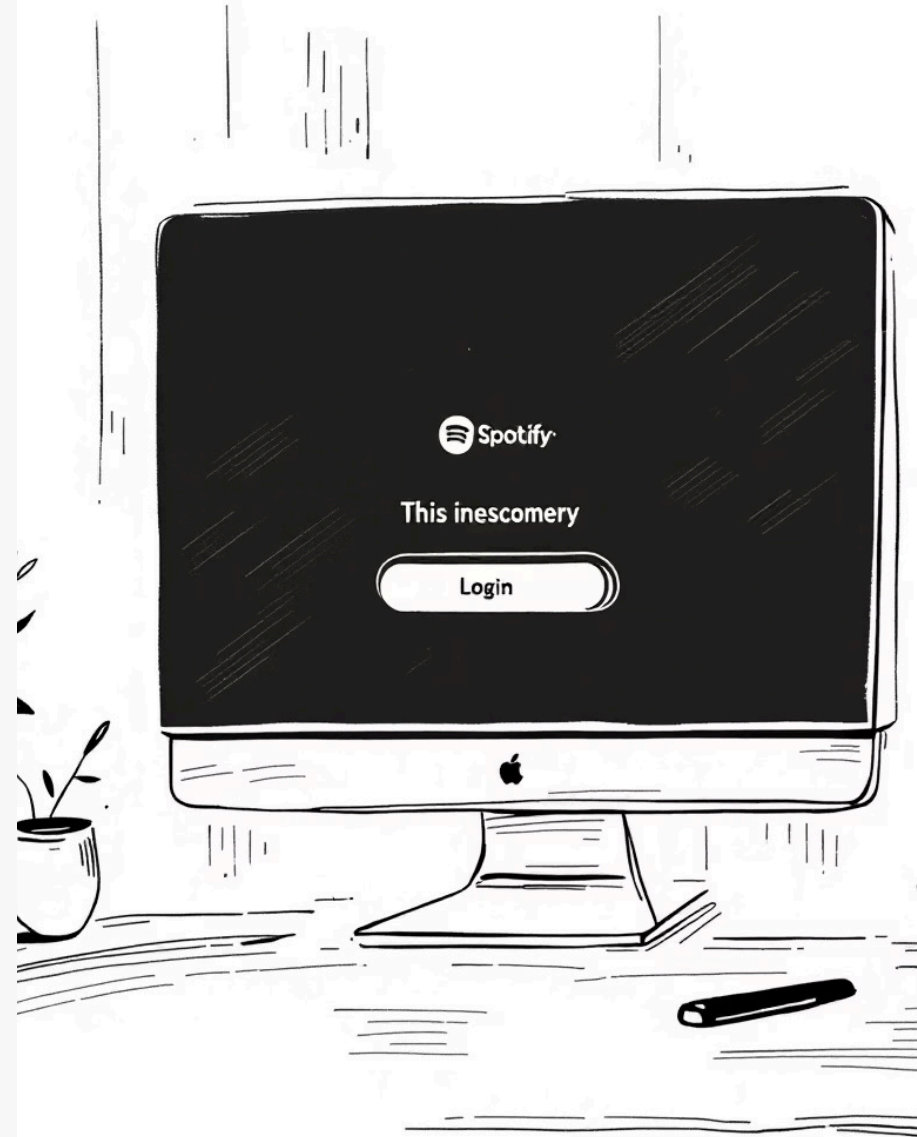
Step 0

User Opens Spotify

- User opens a browser
- Types spotify.com
- Clicks **Login**

At this point

- User is interacting only with Spotify
- No Google involved yet





Step 1

User Chooses Google Login

User clicks "Continue with Google"

Browser is redirected to Google

Key idea

- Browser switches from Spotify → Google
- Spotify pauses the flow temporarily

Step 2

Google Authenticates User

01

Google login page opens

03

Google asks permission:

"Allow Spotify to access your email and profile?"

02

User enters email/password (if not logged in)

04

User clicks **Allow**



This step records user consent

Step 3

Authorization Code Issued

- Google redirects browser back to Spotify
- Redirect URL contains:
 - **Authorization Code**

Example:

```
https://spotify.com/callback?code=abc123
```

Important

- Code is short-lived
- Code cannot access data
- This is NOT an access token

Step 4

Spotify Backend Gets Access Token



1. Browser sends authorization code to Spotify backend



2. Spotify backend calls Google token API

Sends:

- Authorization Code
- Client ID
- Client Secret
- (In OAuth, **Client ID** and **Client Secret** are basically **Spotify's identity credentials** when talking to Google.)

Google responds with

- Access Token
- Refresh Token
- Expiry time

Token Ownership Clarified

Who has what?



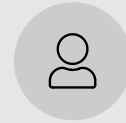
Browser:

- Authorization Code (temporary)



Spotify Backend:

- Google Access Token
- Google Refresh Token



User:

- Spotify session or Spotify JWT



User never sees Google token



Step 5

Spotify Fetches User Profile

Spotify backend uses Google Access Token

Fetches:

- Email
- Profile details

Spotify:

- Creates user account OR
- Logs into existing account

Step 6

User Logged into Spotify

01

Spotify creates:

- Session cookie OR
- Spotify-issued JWT

02

Browser receives Spotify session

03

Spotify home page loads

04

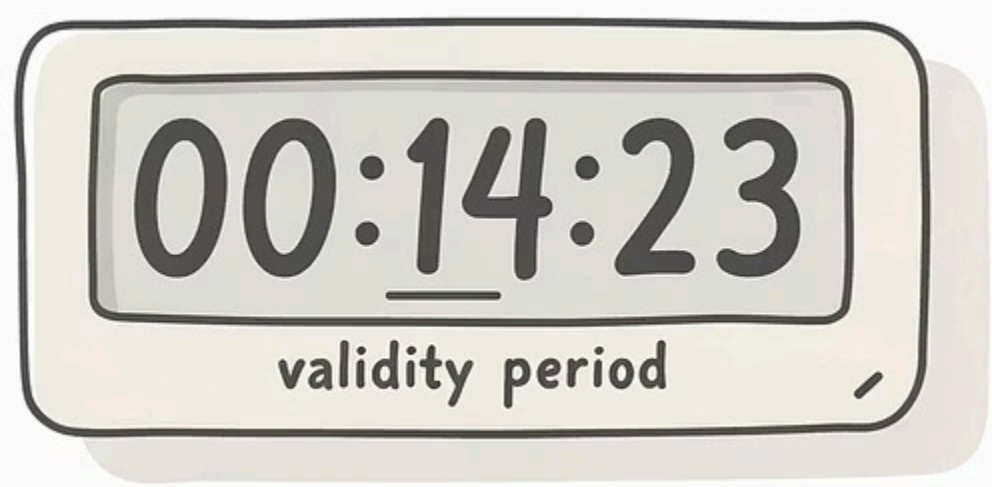
User sees playlists

Login completed

Spotify for rust pllage.



Music personalized witen playlists



Step 7

Token Validity Over Time

- Google access tokens are short-lived
- Spotify stores:
 - Token expiry time

While token is valid

- Spotify uses it
- No Google call needed

Token Refresh Flow (Silent)



When access token expires:

- Spotify backend sends Refresh Token to Google



Google issues:

- New Access Token



Key point

- User is not involved
- No re-login required

When Does Spotify Talk to Google Again?

Spotify contacts Google only when:

Access token expires

Fresh Google data is needed

User reconnects Google account

Not on every user request

Full Flow Summary



User clicks Google Login



Google authenticates & asks consent



Authorization Code sent via browser



Backend exchanges code for token



Spotify fetches user data



User logged in with Spotify session



Tokens refreshed silently in background

Interview One-Liner

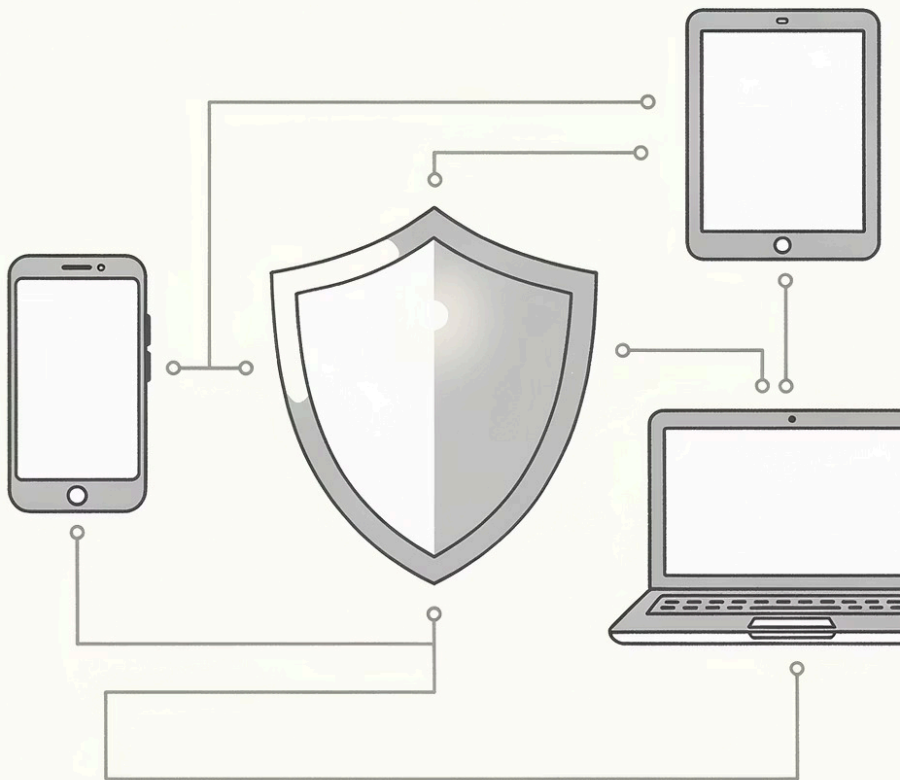
Authorization Code Flow

"The browser carries proof of consent, while access tokens are exchanged securely between servers and refreshed silently without user involvement"

Slide 16

Slide 16 — Why Use Google Login at All?

- Spotify JWT alone is enough for app sessions
 - Spotify can manage login, playlists, and authorization by itself
- Google login adds **convenience**
 - No need to remember a new password
 - One-click login, faster onboarding
- Google login adds trust and security
 - Verified identity (Google already checks your email)
 - Strong authentication (2FA, suspicious login detection)
- Google login enables cross-app consistency
 - You can use the same Google account across multiple apps
- Spotify JWT is still used for daily sessions
 - Google is only involved during:
 - Initial login
 - Token refresh
 - Fetching new Google data



Why Use Google Login at All?

Spotify JWT alone is enough for app sessions

- Spotify can manage login, playlists, and authorization by itself



Google login adds convenience

- No need to remember a new password
- One-click login, faster onboarding



Google login adds trust and security

- Verified identity (Google already checks your email)
- Strong authentication (2FA, suspicious login detection)



Google login enables cross-app consistency

- You can use the same Google account across multiple apps

When Is Google Actually Involved?

Spotify JWT is still used for daily sessions

Google is only involved during:



Initial login



Token refresh



Fetching new Google data

